Luiss
Libera Università Internazionale
degli Studi Sociali Guido Carli

Lab on TOR

Data Privacy and Security

Data Science and Management (DASMA)

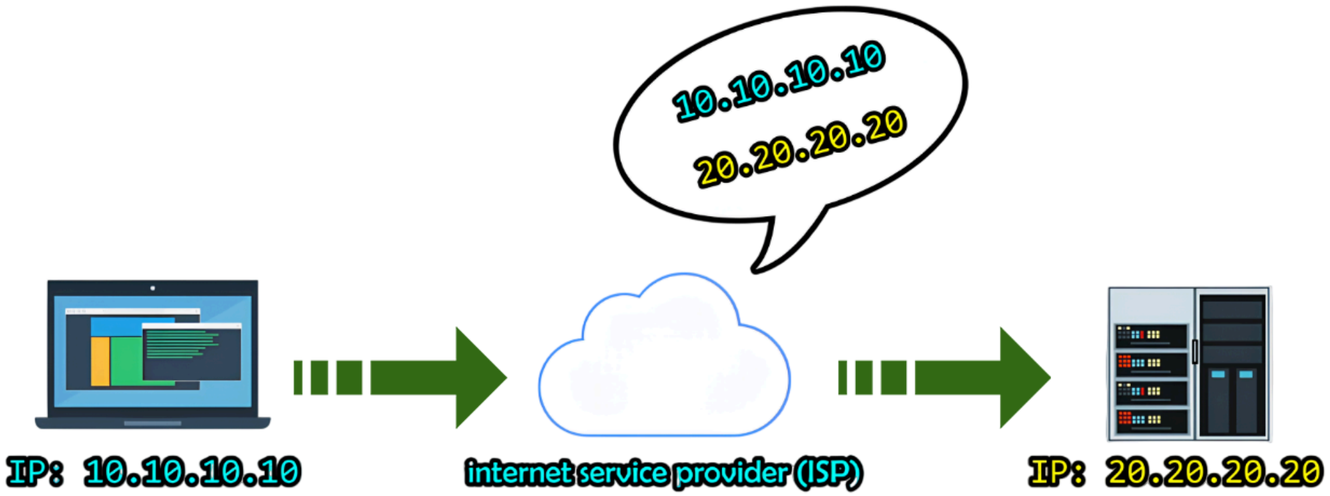
LUISS

Why Do We Need Anonymous Communication?

Whenever you go online you've got an audience you didn't ask for:

- **Your ISP** - they can see everything you do on the Internet
- **Websites** - tracking cookies, fingerprinting
- **Advertisers** - they know your shoe size before you do!
- **Law enforcement** - with a simple request to your ISP
- That one guy at the free coffee shop Wi-Fi

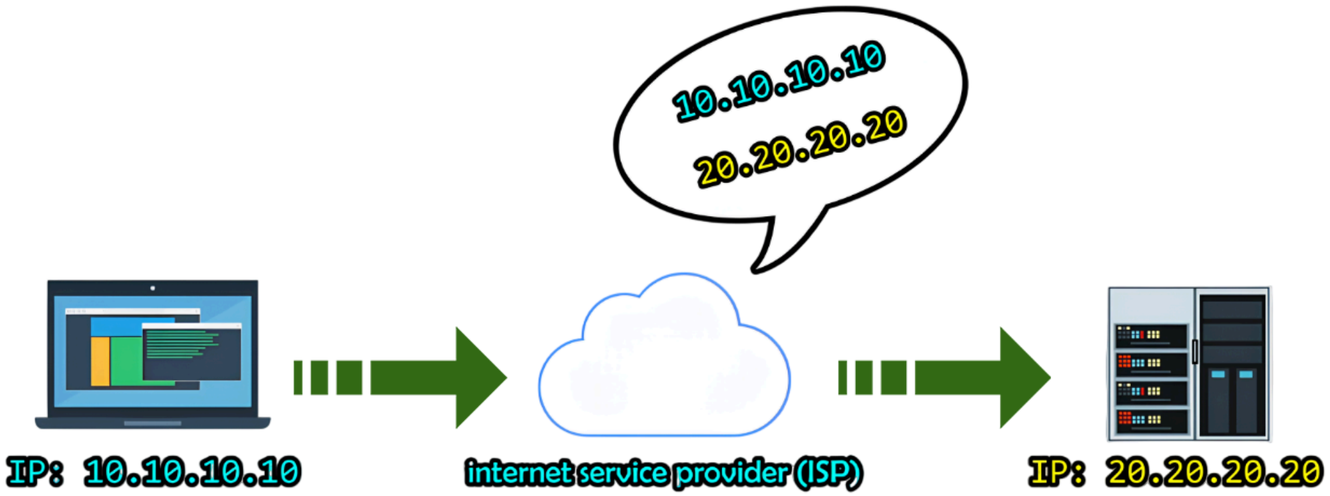
Regular Internet Browsing



Your ISP can see:

- Your IP address (**who** you are)
- The destination website (**where** you go)

Regular Internet Browsing

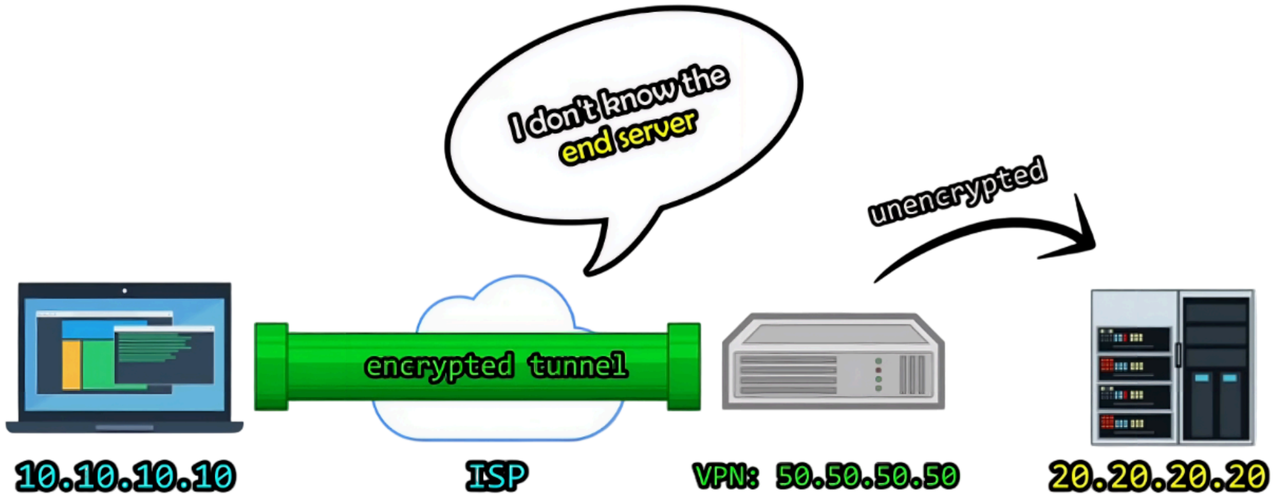


Your ISP can see:

- Your IP address (**who** you are)
- The destination website (**where** you go)

PROBLEM: Even with **HTTPS**, the destination (which website you visit) is still visible to your ISP!

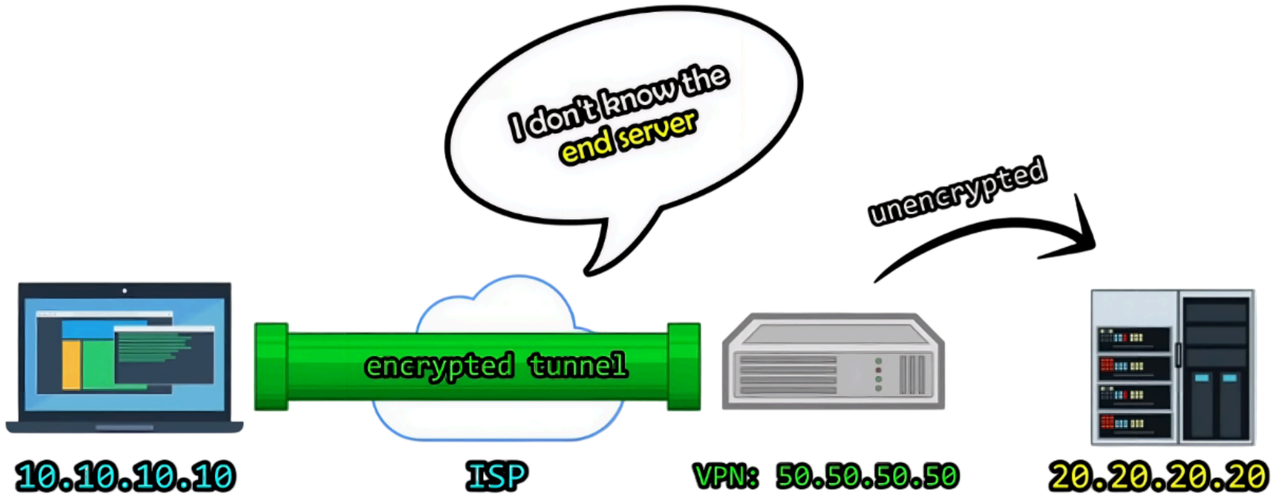
VPN: A First Attempt at Privacy



A **VPN** (Virtual Private Network) creates an encrypted tunnel to a VPN server:

- The ISP sees you connecting to the VPN server, but **not** the final destination (which is encrypted)
- The **VPN provider sees everything**: your IP, the destination, and your traffic

VPN: A First Attempt at Privacy



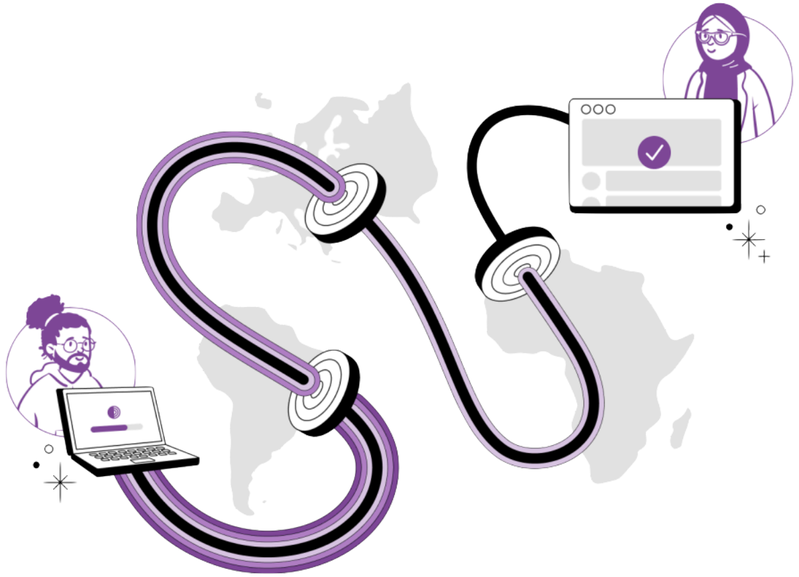
A **VPN** (Virtual Private Network) creates an encrypted tunnel to a VPN server:

- The ISP sees you connecting to the VPN server, but **not** the final destination (which is encrypted)
- The **VPN provider sees everything**: your IP, the destination, and your traffic

PROBLEM: You are just transferring trust from your ISP to the VPN provider!

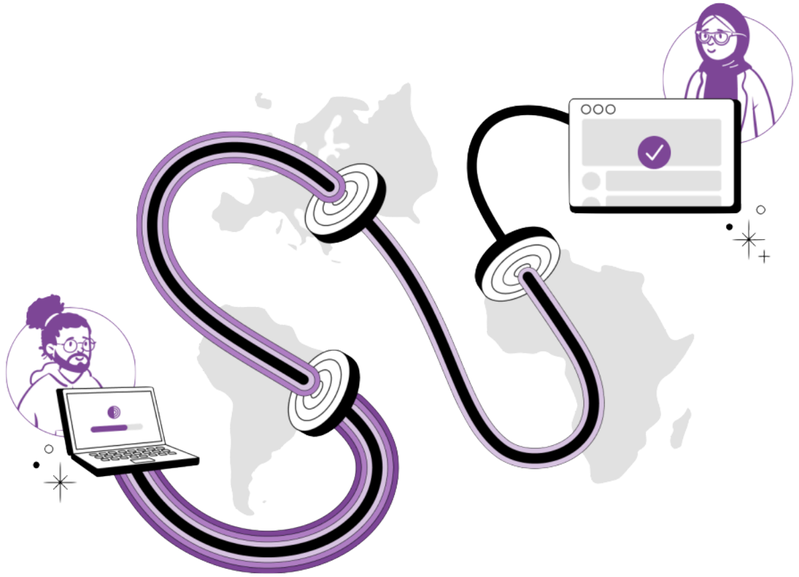
Enter Tor - The Onion Routing

Tor is a free, open-source software for enabling **anonymous communication** over the Internet.



Enter Tor - The Onion Routing

Tor is a free, open-source software for enabling **anonymous communication** over the Internet.

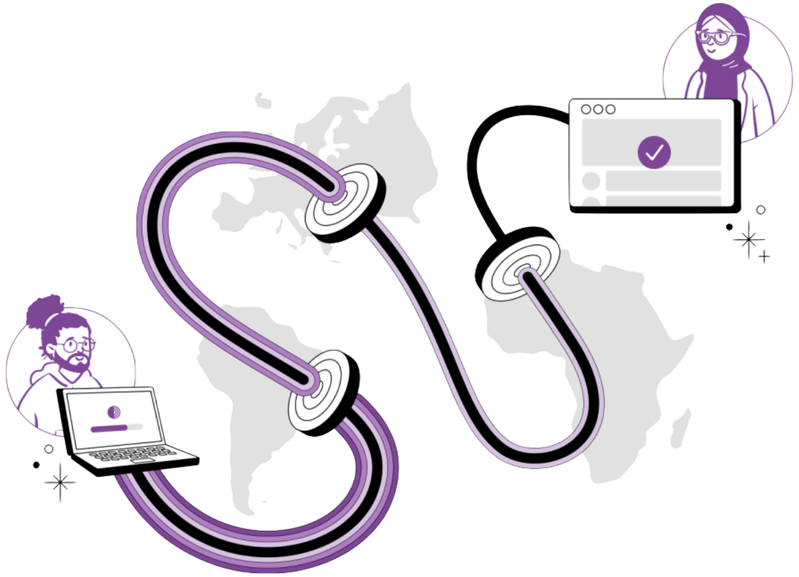


Key properties:

- Routes traffic through a network of **independently-operated servers** (relays)
- Traffic is encrypted in **multiple layers** (like an onion)
- **Decentralized**: no single entity can see both source and destination
- **Open source**: anyone can audit the code and verify its security

Enter Tor - The Onion Routing

Tor is a free, open-source software for enabling **anonymous communication** over the Internet.



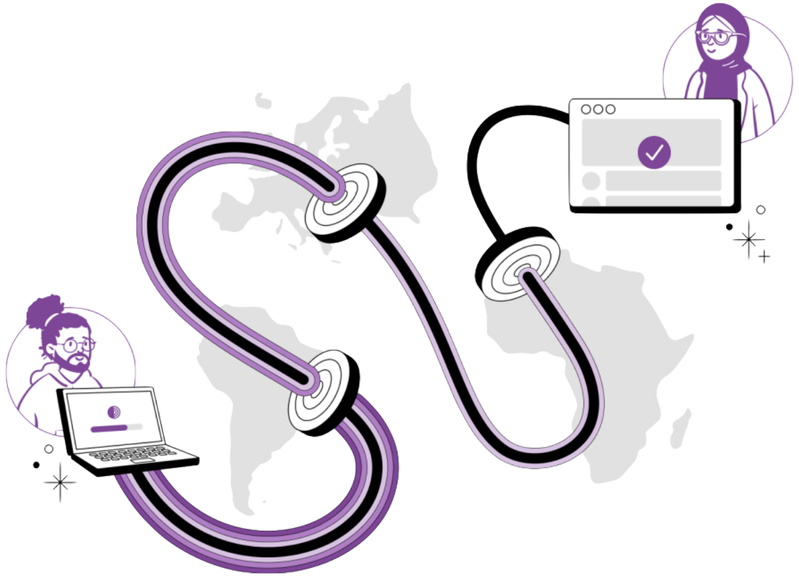
Key properties:

- Routes traffic through a network of **independently-operated servers** (relays)
- Traffic is encrypted in **multiple layers** (like an onion)
- **Decentralized**: no single entity can see both source and destination
- **Open source**: anyone can audit the code and verify its security

Tor provides **privacy by design** – the system is built so that no single party can deanonymize users.

Enter Tor - The Onion Routing

Tor is a free, open-source software for enabling **anonymous communication** over the Internet.



Key properties:

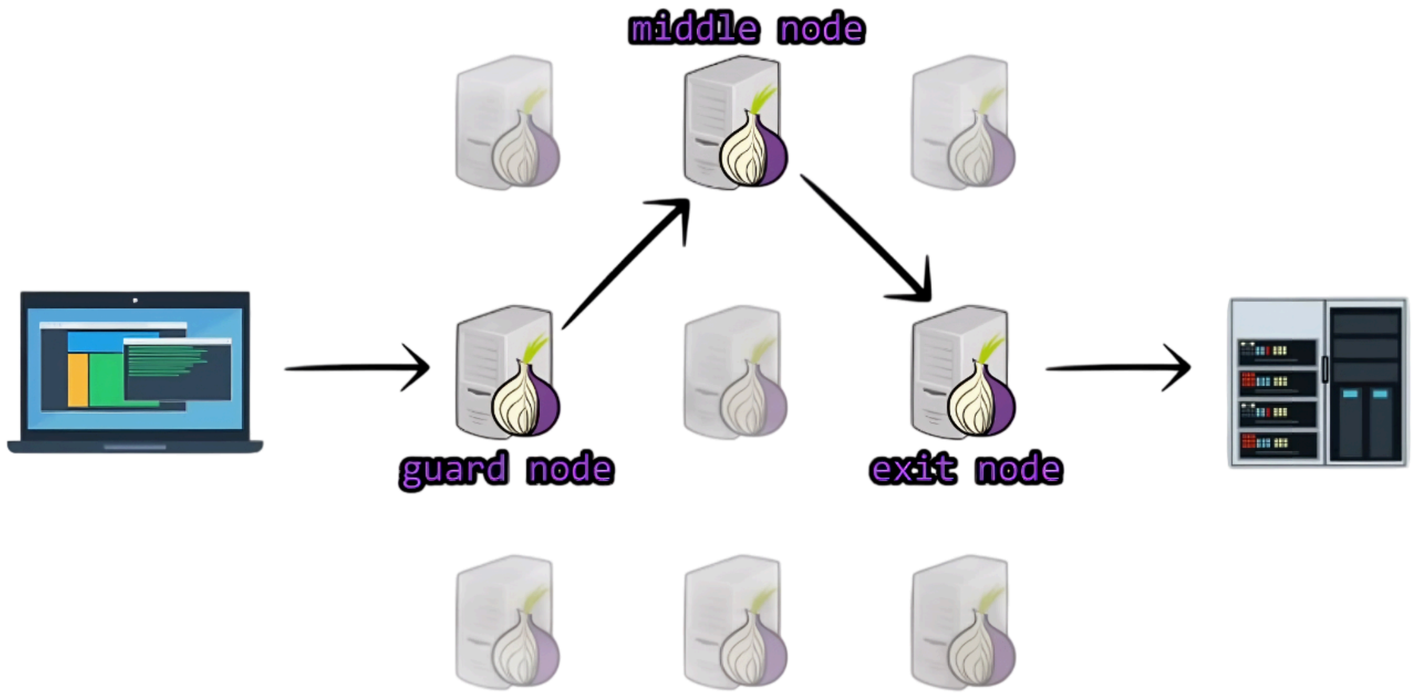
- Routes traffic through a network of **independently-operated servers** (relays)
- Traffic is encrypted in **multiple layers** (like an onion)
- **Decentralized**: no single entity can see both source and destination
- **Open source**: anyone can audit the code and verify its security

Tor provides **privacy by design** – the system is built so that no single party can deanonymize users.

As of 2024: **7,880**+ **relays** and **1,820**+ **bridges** operated by volunteers worldwide.

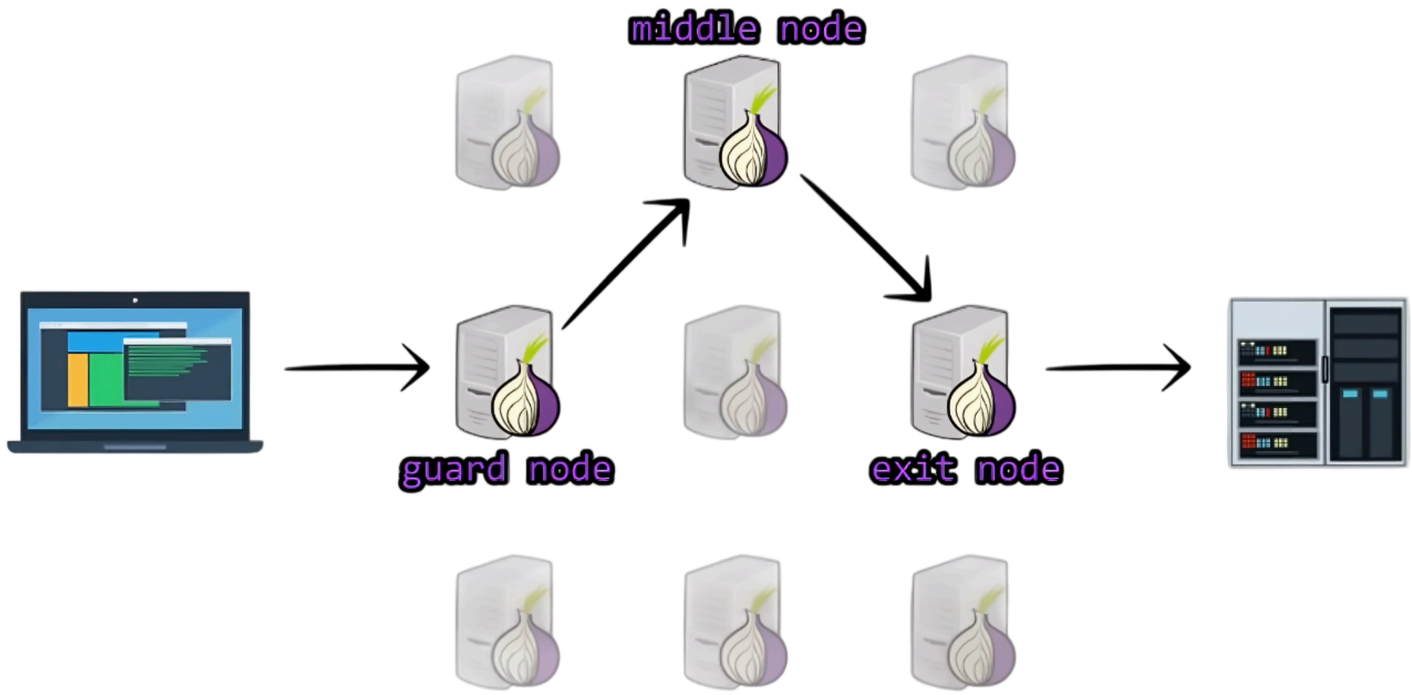
Tor: How it Works

Traffic travels through **3 randomly selected relays** (nodes):



Tor: How it Works

Traffic travels through **3 randomly selected relays** (nodes):



Each node only knows its neighbors - **the full path is never visible to anyone**.

Tor: Why it Works

Why Tor succeeds where other methods fail:

- **No single point of failure** – it relies on 3 independent nodes
- **No trust required** – no node knows both source and final destination address
- **Decentralized** – many volunteer relays worldwide, not one corporate server
- **No logs by design** – nodes physically can't log what they don't know
- **Actually hides your traffic** – unlike incognito mode, which only hides your history from yourself!

Hidden Services (Onion Services)

What are Hidden Services?

So far we have seen how Tor protects the **client** (Alice). But what about the **server**?

What are Hidden Services?

So far we have seen how Tor protects the **client** (Alice). But what about the **server**?

Hidden Services (also called **Onion Services**) allow servers to offer services through Tor **without revealing their IP address**.

What are Hidden Services?

So far we have seen how Tor protects the **client** (Alice). But what about the **server**?

Hidden Services (also called **Onion Services**) allow servers to offer services through Tor **without revealing their IP address**.

Key properties:

- The server's IP address and physical location remain **hidden**
- Accessible only through the Tor network using a `.onion` address
- Traffic between client and server is **end-to-end encrypted** within Tor
- The traffic **never leaves the Tor network** (no exit relay needed)

Example `.onion` address (v3, 56 characters):

`duckduckgogg42xjoc72x3sjasowoarfbgcmvfimaftt6twagswzczad.onion`

- The address is derived from the **site's public cryptographic key**
- This means **the address itself IS the authentication** – no DNS, no certificate authority needed
- **You can't spoof it**: if you reach the address, you're talking to the right server
- **Only accessible through Tor** – your regular browser won't know what to do with it

Why Hidden Services?

The dark web has a reputation... but it's not all criminal:

- **Whistleblowing platforms**: SecureDrop (used by The New York Times, The Guardian, etc.)
- **Censorship-free forums**: news organizations, blogs in repressive regimes
- **Private communication**: messaging services that resist surveillance
- **Self-hosted services**: personal servers accessible without exposing your home IP

Why Hidden Services?

The dark web has a reputation... but it's not all criminal:

- **Whistleblowing platforms**: SecureDrop (used by The New York Times, The Guardian, etc.)
- **Censorship-free forums**: news organizations, blogs in repressive regimes
- **Private communication**: messaging services that resist surveillance
- **Self-hosted services**: personal servers accessible without exposing your home IP

Many major websites offer `.onion` mirrors: Facebook, DuckDuckGo, BBC, ProtonMail, The New York Times, etc.

A Practical Guide to Tor Browser

Installing Tor Browser

The official download is at torproject.org – and **ONLY** there.

...but our lovely university Wi-Fi has other plans, so today we'll be using a mirror:

techspot.com/downloads/5183-tor-browser.html

How can you be sure it's safe? **Verify its hash**:

- Expected SHA256 hash (Windows installer): 958626901dbe17fc003ed671b61b3656375e6f0bc06c9dff60bd2f80d4ace21b
- Expected SHA256 hash (MacOS installer): 29852c4f3aa3b77bccdf359c5a22cf3ffa49ad1828b3967fb722134ffdc29e20

How to Compute SHA256 Hash of a File

Option A: upload it to VirusTotal (virustotal.com), which will display the hash at the top of the results page.

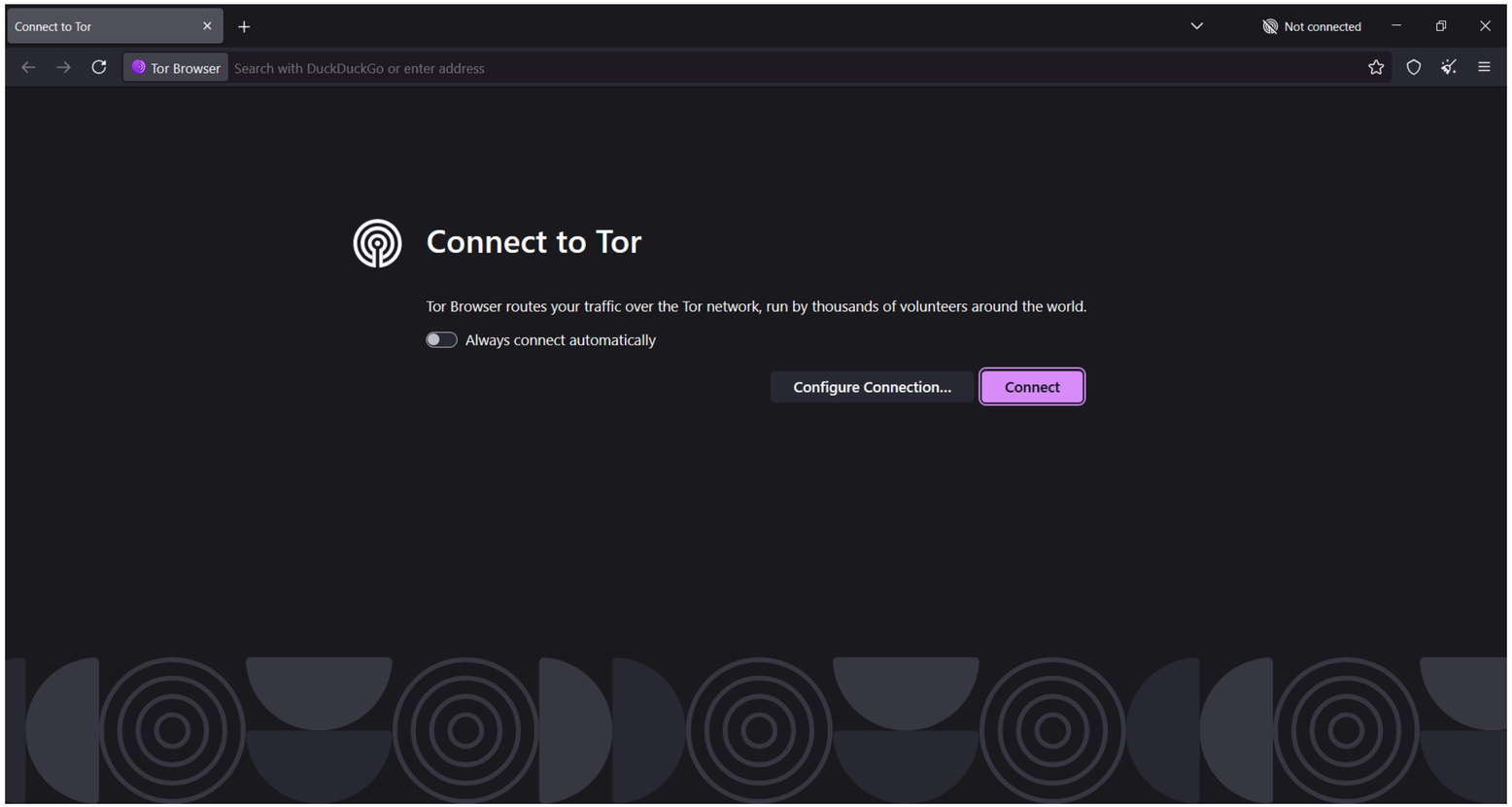
Option B: command line:

- Windows: `certutil nameofthefile.exe SHA256`
- MacOS: `shasum -a 256 nameofthefile.dmg`

> If they match the file is untampered i.e. **safe to use**

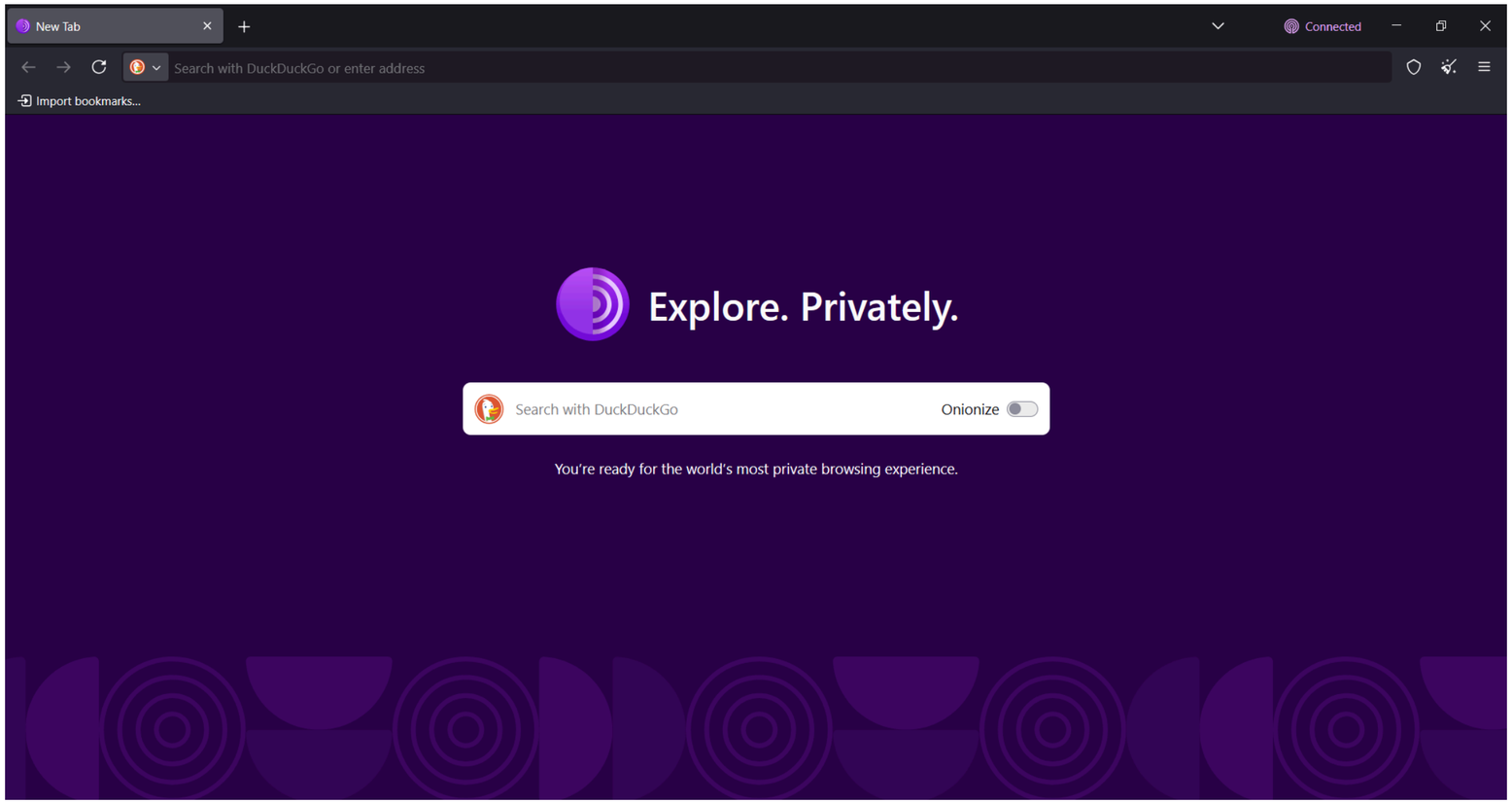
Tor Browser: Interface Overview

Hit **Connect** and Tor will establish a circuit through 3 random relays.



Tor Browser: Interface Overview

Success screen:



Tor Browser: Golden Rule(s)

DO **NOT** change the default settings. DO **NOT** install extensions. DO **NOT** "customize" things.

Why? Tor's anonymity works because every user looks the same - you don't want to stand out!

Tor Browser: Golden Rule(s)

> DO **NOT** change the default settings. DO **NOT** install extensions. DO **NOT** "customize" things.

Why? Tor's anonymity works because every user looks the same - you don't want to stand out!

Settings You **CAN** Touch:

- Bridges – hides the fact you're using Tor (useful where Tor is blocked)
- HTTPS-Only Mode – enable in all windows (should be default)
- Security Level – Safe / Safer / Safest
- Search Engine – default is DuckDuckGo, keep it privacy-friendly

Tor Browser: DOs and DONTs

DOs:

- Use it for **anonymous activities** (research, reading, browsing)
- Use `.onion` links when available (sites only accessible through Tor)
- **Keep Tor updated** – always use the latest stable version
- **Be boring**. Blend in. Don't stand out.

DONTs

- DON'T **log into your personal accounts** (congratulations, you just deanonymized yourself!)
- DON'T **open downloaded files** without disconnecting first (they may contact external servers outside Tor)
- DON'T **brag** about using Tor on social media **with your real name** (bye bye anonimity!)

Time to Cook

SilkRoadUniversity

TOR Challenge 01

SilkRoadUniversity - Reconnaissance

SilkRoadUniversity (500 points) tor

You can easily pass your exams thanks to SilkRoadUniversity... join the dark side ;)

https://tor01.webhack.it

Flag

Submit

What can we observe? The challenge...

- presents a **dark-web academic marketplace** accessible only via a `.onion` address;
- provides a **personal access token** tied to the user's email;
- requires a **working Tor Browser setup** to reach the hidden service and claim the flag.

SilkRoadUniversityFranchiseProgram

TOR Challenge 02

SilkRoadUniversityFranchiseProgram - Reconnaissance

SilkRoadUniversityFranchiseProgram (500 points) tor

You can now make money by cheating!

https://tor02.webhack.it

Flag

Submit

What can we observe? The challenge...

- provides step-by-step instructions to spin up a Tor hidden service using Docker;
- requires **embedding a personal franchise license code** in the hidden service's homepage;
- asks for the resulting `.onion` address to verify it against the given license code.

Setting up your .onion hidden service

We said Tor can host websites, not just browse them. Let's prove it!

We'll spin up a hidden service using Docker – a server that's **only reachable through the Tor network**.

- No domain registrar,
- No hosting provider,
- No paper trail.

Just you, an onion address, and 56 characters of pure anonymity.

What you need

Three ingredients:

- A **web server** e.g. Nginx, serving a simple HTML page
- A **Tor daemon** – connects to the Tor network and creates the `.onion` address
- **Docker** – glues everything together

Hidden service's folder structure:

```
my-hidden-service/
├── docker-compose.yml
├── torrc
└── www/
    └── index.html
```

Step 1: The Web Page

Create a simple `index.html` file and store it in the www folder:

```html
<html>
<body>
  <h1>My Secret Onion Shop</h1>
  <p>If you can read this, welcome to Tor.</p>
</body>
</html>
```

Step 2: The Tor Configuration

Create a `torrc` file:

```
SocksPort 0
HiddenServiceDir /var/lib/tor/hidden_service/
HiddenServicePort 80 web:80
Log notice stdout
```

- SocksPort 0 – we're not browsing, just hosting
- HiddenServiceDir – where Tor stores your keys and .onion address
- HiddenServicePort 80 web:80 – maps .onion port 80 to the Nginx container

Step 3: Docker Compose

```yaml
services:
  web:
    image: nginx:alpine
    volumes:
      - ./www:/usr/share/nginx/html:ro

  tor:
    image: alpine:3.19
    command: sh -c "apk add --no-cache tor && chmod 700 /var/lib/tor/hidden_service
&& tor -f /etc/tor/torrc"
    volumes:
      - ./torrc:/etc/tor/torrc:ro
      - tor_data:/var/lib/tor/hidden_service
    depends_on:
      - web

volumes:
  tor_data:
```

Step 4: Launch and Wait

```
docker compose up -d
docker compose logs -f tor
```

Wait for the magic words:

```
Bootstrapped 100% (done): Done
```

> This takes 30–60 seconds. Tor is generating your keys, building circuits, and publishing your service descriptor to the network.

Step 5: Get your .onion address

```
docker compose exec tor cat /var/lib/tor/hidden_service/hostname
```

You'll get something like:

`x3b2yi7kfcq...something...d.onion`

That's it. That's your address. Paste it in Tor Browser and you'll see your page!